

DDTA – Facial Access Project Documentation

Documentation-Driven Threat Analysis

Working project documentation – R24

1 Project Problem Framing

Il progetto affronta il problema di controllare l'accesso a un'area fisica riservata, determinando se una persona che si presenta a un punto di accesso possa entrare e rendendo possibile l'apertura del varco solo quando le condizioni di accesso previste dall'organizzazione risultano soddisfatte.

Rientrano nel problema la gestione delle condizioni che determinano chi può accedere, la verifica della persona che si presenta, la decisione relativa all'accesso e le conseguenze dell'uso di informazioni personali o biometriche necessarie al processo.

2 MacroRequirements

MR-0001 – Controllo dell'accesso all'area riservata

Intent

Consentire a `*<ControlledAreaAccess>` di determinare se un tentativo di accesso all'area riservata possa essere consentito, usando `#<IdentityVerificationEvidence>` e `#<AccessAuthorizationState>` per `@<produce>` `#<AccessDecision>` coerente con le condizioni stabilite dall'organizzazione.

Context

Nel controllo di un accesso, la decisione relativa al tentativo deve essere formulata tenendo insieme due informazioni concettualmente distinte: l'evidenza relativa alla verifica della persona che si presenta e lo stato di autorizzazione associato all'identità governata rilevante. `*<ControlledAreaAccess>` costituisce il punto del problema in cui tali informazioni assumono significato congiunto ai fini della decisione di accesso.

Scope

Rientrano nella responsabilità il controllo del tentativo di accesso, la determinazione dell'esito sulla base delle condizioni necessarie e il fatto che l'accesso possa essere reso possibile quando tale esito lo consente.

Non rientrano nella responsabilità la definizione e il mantenimento delle autorizzazioni di accesso, la gestione delle identità, la verifica della persona che si presenta al punto di accesso né le scelte tecniche con cui la decisione o l'apertura del varco vengono realizzate.

ID

MR-0001

Lifecycle

current

Stakeholders

- persone che si presentano al punto di accesso;
- organizzazione responsabile dell'area riservata e delle condizioni di accesso.

Assumptions

Nessuna assunzione macro esplicita.

Constraints

Nessun vincolo macro esplicito.

dependsOn

MR-0002

MR-0003

MR-0002 – Gestione delle autorizzazioni di accesso

Intent

Consentire a `*<AccessAuthorizationManagement>` di stabilire e mantenere nel tempo lo stato delle autorizzazioni di accesso definite dall'organizzazione, di `@<correlate>` `#<AccessAuthorizationState>` con la relativa `#<GovernedIdentity>` e di `@<produce>` `#<AccessAuthorizationState>` aggiornato e utilizzabile da `*<ControlledAreaAccess>`.

Context

L'autorizzazione di accesso esprime una condizione attribuita dall'organizzazione a una `#<GovernedIdentity>` e rilevante per stabilire se l'accesso possa essere consentito. Tale condizione può essere mantenuta nel tempo indipendentemente dalla presenza di una persona al punto di accesso e viene rappresentata, per il processo di accesso, mediante `#<AccessAuthorizationState>`.

Scope

Rientrano nella responsabilità la definizione e il mantenimento nel tempo delle autorizzazioni di accesso associate alle identità governate e la disponibilità dello stato di autorizzazione necessario al controllo dell'accesso.

Non rientrano nella responsabilità la gestione delle identità a cui le autorizzazioni si riferiscono, la verifica della persona che si presenta al punto di accesso, la decisione relativa al singolo tentativo di accesso né le modalità tecniche con cui le autorizzazioni vengono memorizzate, aggiornate o rese disponibili.

ID

MR-0002

Lifecycle

current

Stakeholders

- organizzazione e soggetti da essa delegati alla gestione delle autorizzazioni;
- persone alle cui identità sono associate autorizzazioni di accesso.

Assumptions

Nessuna assunzione macro esplicita.

Constraints

Nessun vincolo macro esplicito.

dependsOn

MR-0004

MR-0003 – Verifica della persona al punto di accesso

Intent

Consentire a `*<IdentityVerification>` di stabilire a quale `#<GovernedIdentity>` corrisponde `#<PersonAtAccessPoint>`, e di `@<produce>` `#<IdentityVerificationEvidence>` utilizzabile da `*<ControlledAreaAccess>`.

Context

Al punto di accesso, `#<PersonAtAccessPoint>` e `#<GovernedIdentity>` rappresentano significati distinti: il primo riguarda la persona che si presenta in quel momento, mentre il secondo costituisce il riferimento governato al quale la persona può essere ricondotta. `*<IdentityVerification>` riguarda la determinazione di questa corrispondenza e la disponibilità della relativa `#<IdentityVerificationEvidence>`.

Scope

Rientrano nella responsabilità la verifica della persona che si presenta al punto di accesso, la determinazione della sua corrispondenza con una identità governata e la disponibilità dell'evidenza risultante necessaria al controllo dell'accesso.

Non rientrano nella responsabilità la gestione delle identità governate, la definizione o il mantenimento delle autorizzazioni di accesso, la decisione relativa al singolo tentativo di accesso né le modalità tecniche con cui la verifica viene realizzata.

ID

MR-0003

Lifecycle

current

Stakeholders

- persone che si presentano al punto di accesso;
- organizzazione che utilizza l'evidenza di verifica nel processo di accesso.

Assumptions

Nessuna assunzione macro esplicita.

Constraints

Nessun vincolo macro esplicito.

dependsOn

MR-0004

MR-0004 – Gestione delle identità

Intent

Consentire a ***<IdentityManagement>** di @**<create>** e mantenere le #**<GovernedIdentity>** necessarie al controllo degli accessi, rendendole disponibili alle responsabilità di progetto che devono riferirsi a un'identità governata.

Context

Le diverse responsabilità coinvolte nel controllo degli accessi devono poter fare riferimento in modo coerente alle stesse identità nel tempo. ***<IdentityManagement>** rende disponibile questo riferimento governato attraverso #**<GovernedIdentity>**, permettendone il riuso nei diversi momenti in cui il progetto deve riferirsi all'identità di una persona.

Scope

Rientrano nella responsabilità la creazione e il mantenimento nel tempo delle identità governate necessarie al controllo degli accessi e la loro disponibilità alle altre responsabilità di progetto che devono riferirsi in modo coerente all'identità di una persona.

Non rientrano nella responsabilità la definizione o il mantenimento delle autorizzazioni di accesso associate alle identità, la verifica della persona che si presenta al punto di accesso, la decisione relativa al singolo tentativo di accesso né le modalità tecniche con cui le identità vengono rappresentate, memorizzate o gestite.

ID

MR-0004

Lifecycle

current

Stakeholders

- organizzazione e soggetti da essa delegati alla gestione delle identità;
- persone alle quali le #**<GovernedIdentity>** si riferiscono.

Assumptions

Nessuna assunzione macro esplicita.

Constraints

Nessun vincolo macro esplicito.

dependsOn

Nessuna dipendenza MR esplicita.

3 Decisions

ADR-0001 – Politica congiuntiva per la decisione di accesso

Context

*<ControlledAreaAccess> determina #<AccessDecision> utilizzando #<AccessAuthorizationState> e #<IdentityVerificationEvidence>, che rappresentano condizioni distinte del controllo dell'accesso.

Il MacroRequirement stabilisce che entrambe partecipino alla determinazione dell'esito, ma non stabilisce quale relazione debba intercorrere tra i rispettivi esiti affinché l'accesso possa essere consentito. In particolare, resta da stabilire se ciascuna condizione sia necessaria oppure se una delle due possa risultare sufficiente in assenza dell'altra.

Decision

Il progetto adotta una **politica congiuntiva** per #<AccessDecision>: l'accesso può essere consentito soltanto quando #<AccessAuthorizationState> indica che la relativa identità governata è autorizzata e #<IdentityVerificationEvidence> supporta positivamente la verifica della persona che si presenta al punto di accesso.

#<AccessAuthorizationState> e #<IdentityVerificationEvidence> costituiscono entrambe condizioni necessarie; nessuna delle due è sufficiente, da sola, a determinare un #<AccessDecision> che consenta l'accesso.

Consequences

- una verifica positiva della persona non attribuisce né sostituisce l'autorizzazione di accesso;
- un'autorizzazione valida non sostituisce la verifica della persona richiesta dal processo di accesso;
- il comportamento funzionale successivo deve preservare la congiunzione delle due condizioni;
- il significato di verifica positiva, la gestione degli esiti non conclusivi e le modalità con cui autorizzazione e verifica vengono ottenute restano scelte separate.

Parent MacroRequirement
MR-0001

Title

Politica congiuntiva per la
decisione di accesso

4 FunctionalRequirements

FR-0001 – Determinazione congiuntiva dell'esito di accesso

Parent Decision ADR-0001

Obbligazione funzionale

Quando *<ControlledAreaAccess> determina #<AccessDecision> per un tentativo di accesso, deve considerare #<AccessAuthorizationState> e #<IdentityVerificationEvidence> rilevanti per tale decisione. *<ControlledAreaAccess> **DEVE** produrre un #<AccessDecision> che consenta l'accesso solo quando:

- #<AccessAuthorizationState> indica un'autorizzazione valida; e
- #<IdentityVerificationEvidence> supporta positivamente la verifica della persona.

Quando almeno una delle due condizioni non risulta soddisfatta, *<ControlledAreaAccess> **DEVE** produrre un #<AccessDecision> che non consenta l'accesso.